



CARGO BIT SECURITY

Compliance Documentation

ISO 27001 and SOC2 controls mapping with evidence artifacts for audit readiness.

CargoBit Platform

Version 1.0

April 2026

CONFIDENTIAL

1. Scope

Dieses Dokument definiert die Compliance-Abdeckung des Hybrid Security Layer. Scope: Security Gateway, Risk Engine, Mitigation Service, Audit Service, Notification Service.

2. ISO 27001 Mapping

Kapitel	Control	Implementation
A.5	Policies	Security Policies dokumentiert
A.8	Asset Management	Service-Inventar, Data Classification
A.12	Operations Security	Monitoring, Logging, Incident Response
A.16	Incident Management	Playbooks + Runbooks, 24/7 On-Call

3. SOC2 Mapping

Trust Service	Control	Implementation
Security	Access Controls, Encryption	RBAC, AES-256, Immutable Audit
Availability	Autoscaling, Circuit Breakers	Kubernetes HPA, resilience4j
Processing Integrity	Risk-Scoring	Deterministic Rules, State Machines
Confidentiality	Data Minimization	PII-Scrubbing, TLS 1.3
Privacy	Retention Policies	Audit: 5 Jahre, Risk: 2 Jahre

4. Key Compliance Features

- Immutable Audit-Trail: WORM-Storage, Hash-Chain
- Least Privilege RBAC: Granulare Berechtigungen, SoD
- Zero-Trust Service-Auth: mTLS + JWT
- Secrets Management: Vault-basiert, 24h Rotation

5. Evidence Artifacts

Artifact	Format	Location
Architecture Diagrams	C4 / PNG	Confluence / Git
Audit Log Samples	JSON	Secure Storage

Risk Rules Documentation	Markdown	Git Repository
Monitoring Dashboards	Grafana	Internal URL